

Modern Cloud Computing

Lecture 12: Cloud Security

Chongzhou Fang

Rochester Institute of Technology

Today's Topics

- Cloud Security Risks and Attack Surfaces
- Privacy and Trust
- OS and VM Security
- Mobile-Cloud Security

Cloud Security Risks and Attack Surfaces

Cloud Security

Cloud computing offers:

- Provider-operated infrastructure
- Lower cost through resource sharing
- Elastic scaling

But the same properties create security tension:

- Provider control reduces user visibility
- Resource sharing creates multi-tenancy risks
- Elasticity can be abused by attackers

Comparison

Traditional enterprise computing:

- Users control servers, networks, and storage
- Sensitive data often stays inside a local infrastructure
- Security policies are enforced within one organization

Cloud computing:

- Data and computation move to a Cloud Service Provider (CSP)
- Resources are shared by many users and tenants
- Users must trust provider policies and infrastructure

Different trust boundary.

Data Is Vulnerable in Different States

Cloud data can be attacked while:

- **At rest**
 - Stored in disks, object stores, backups, snapshots
- **In transit**
 - Moving between users, services, data centers, or replicas
- **In use**
 - Decrypted and processed in memory or CPU

Data at rest lasts longer and is often the primary target.

Data in use is exposed for a shorter time, but it is harder to protect.

Data Lifecycle, Standards, and Auditing

Control over the data lifecycle

- Virtually impossible to verify that data that *should* have been deleted **actually was**, and no guarantee the media was wiped before the next tenant.
- CSPs rely on **seamless backups** made without user knowledge or consent; records can be lost, accidentally deleted, or exposed.

Lack of standardization

- No interoperability standards.
- **Auditing and compliance** are a different challenge: a full audit trail on a cloud is currently **infeasible**.
- Autonomic features make it **even harder** to determine *when* an action occurred and *why*.

Multi-Tenancy: Root of Many Concerns

Multi-tenancy enables cloud economics.

- Multiple users share servers
- Multiple VMs share physical hosts
- Multiple customers share SaaS databases and applications
- Provider achieves higher utilization and lower cost

But multi-tenancy creates risks:

- Side channels
- Misconfiguration of isolation boundaries
- Data leakage across tenants
- “Noisy neighbor” and denial-of-service risks

What Should Cloud Users Do?

1. **Evaluate** CSP's security policies and the mechanisms in place to enforce them.
2. **Analyze** which information will actually be stored and processed on the cloud.
3. **Define** the contractual obligations.

The contract should state clearly:

1. CSP obligations to handle sensitive information and to comply with privacy laws.
2. CSP liabilities for mishandling sensitive information, e.g., data loss.
3. The rules governing **ownership** of the data.
4. The **geographical regions** where information and backups can be stored.

Data minimization: avoid processing sensitive data on a cloud where possible; otherwise, **encrypt** it.

Cloud Security Risk Classes

1. **Traditional security threats:** familiar Internet threats, with cloud-specific twists and amplified impact.
2. **Threats to system availability:** failures, outages, and catastrophic events; also correctness of results.
3. **Threats related to third-party data control:** lack of transparency and limited user control.

Traditional Threats, Cloud Scale

Clouds still face traditional Internet threats:

- Distributed denial of service attacks
- Phishing
- SQL injection
- Cross-site scripting
- Credential theft

But cloud scale amplifies their impact:

- More users can be affected
- More resources can be abused
- Attacks can move across tenants and services
- Attribution and forensics become harder

Availability Risks

Availability is a major part of cloud security.

Cloud services can fail because of:

- System failures
- Power outages
- Resource exhaustion
- Provider operational mistakes

Third-Party Data Control

Cloud users delegate control to CSPs.

Risks include:

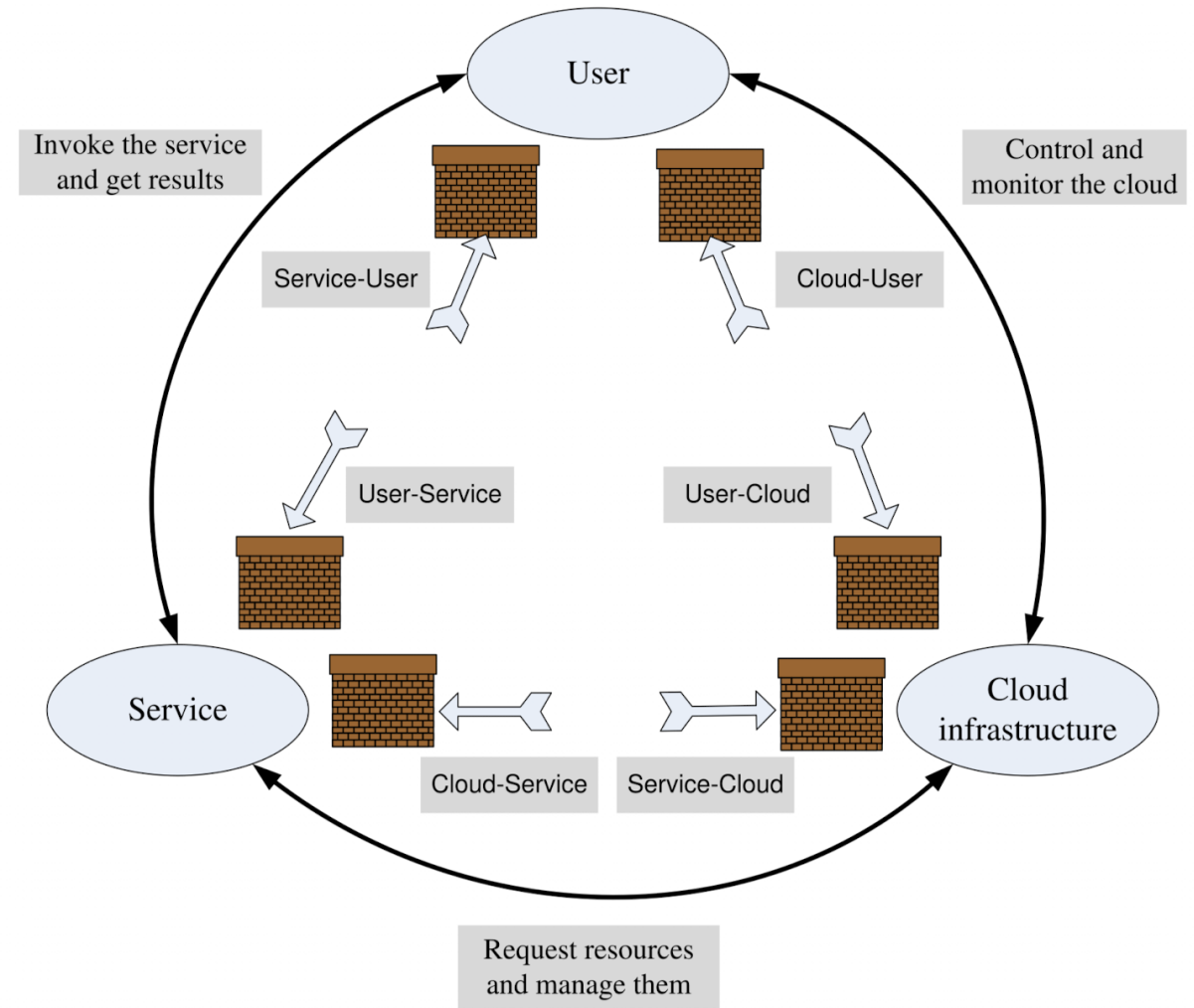
- Provider subcontractors
- Lack of transparency
- Difficult auditing

Attack Surfaces in Cloud Computing

Three actors: **user**, **service**, **cloud infrastructure**

Six directed attack surfaces:

- Service → User: SSL spoofing, browser cache attacks, phishing
- User → Service: SQL injection, buffer overflow, privilege escalation
- Cloud → Service: resource limitation, injected operations
- User → Cloud: attacks on cloud control systems
- Service → Cloud: excessive resource requests
- Cloud → User: infrastructure-originating attacks



CSA 2010 Report: Cloud Threats

Threat	Meaning
Abuse of cloud	Use cloud resources for attacks or malware
Insecure APIs	Weak interfaces for authentication, monitoring, or control
Malicious insiders	Provider employees or insiders misuse access
Shared technology	Isolation failures in multi-tenant infrastructure
Account hijacking	Credentials are stolen or misused
Data loss/leakage	Data is exposed, deleted, or corrupted
Unknown risk profile	Users underestimate hidden risks

Source: [Cloud Security Alliance](#)

CSA 2016 Report: Top Threats

1. **Data breaches:** Unauthorized access exposes sensitive data, including financial records, health information, and intellectual property. (Mitigation: Use **multifactor authentication**, encryption, and strict access controls.)
2. **Compromised credentials / broken authentication:** Stolen credentials or authentication flaws allow attackers to impersonate legitimate users. (Mitigation: Enforce **MFA**, protect credentials, and revoke compromised access promptly.)
3. **Hacked interfaces and APIs:** Weak APIs allow unauthorized access to data or cloud operations. (Mitigation: **Validate inputs**, enforce authorization checks, and protect API credentials.)
4. **Exploited system vulnerabilities:** Attackers exploit software flaws to steal data, gain privileges, or disrupt services. (Mitigation: **Patch promptly**, scan for vulnerabilities, and harden system configurations.)
5. **Account hijacking:** Attackers take over legitimate accounts to manipulate data or misuse cloud resources. (Mitigation: Use **MFA**, monitor unusual activity, and maintain protected audit logs.)
6. **Malicious insiders:** Employees or contractors intentionally misuse authorized access to steal data or damage systems. (Mitigation: **Segregate duties**, enforce least privilege, and monitor and audit privileged activity.)

CSA 2016 Report: Top Threats - Cont'd

7. **Advanced persistent threats (APTs):** Attackers maintain hidden access over long periods, moving between systems and stealing data. (Mitigation: **continuous monitoring**, network segmentation, and phishing awareness training.)
8. **Permanent data loss:** Data becomes unrecoverable through deletion, disasters, attacks, or lost encryption keys. (Mitigation: **independent backups**, recovery testing, and secure key management.)
9. **Inadequate due diligence:** Adopting cloud services without assessing provider security, business risks, or customer responsibilities. (Mitigation: **risk assessments**, provider reviews, and clearly defined contractual obligations.)
10. **Cloud service abuse:** Attackers use cloud resources for spam, phishing, malware hosting, or attacks against others. (Mitigation: **usage monitoring**, abuse detection, and incident response.)
11. **DoS attacks:** Attackers overwhelm or disrupt services, preventing legitimate access and potentially increasing usage charges. (Mitigation: **traffic filtering**, rate limiting, and DDoS protection.)
12. **Shared technology vulnerabilities:** Flaws in shared hardware or software, such as hypervisors, can break isolation and expose multiple tenants to compromise. (Mitigation: **strong tenant isolation**, patching, and infrastructure monitoring.)

Security by Delivery Model

Model	Main security concern
SaaS	User data, identity, provider-side application security, privacy
PaaS	API security, runtime isolation, service integration, application dependencies
IaaS	VM security, images, hypervisors, virtual networks, management plane

Responsibility boundaries change across service models.

Privacy and Trust

Privacy in Cloud Computing

Privacy is the right to keep personal or proprietary information from being disclosed.

Cloud privacy is difficult:

- Data may reside on CSP-owned servers
- Location may be unknown to the user
- Services may collect metadata and logs
- Secondary use may be hard to prevent
- Data may cross borders
- Subcontractors may be involved

Four Major Cloud Privacy Concerns

Concern	Meaning
Lack of user control	Users cannot fully control where data is stored or how long backups remain
Unauthorized secondary use	CSPs or partners may use data for other purposes
Data proliferation	Replicas, backups, and logs spread data across systems
Dynamic provisioning	Outsourcing and subcontracting obscure who controls data

Trust in Cloud Computing

Two conditions for trust to develop

- **Risk:** the perceived probability of loss. Without risk, trust is unnecessary.
- **Interdependence:** one entity's interests cannot be achieved without reliance on others.

Phases and Types of Trust

Different forms of trust:

- **Deterrence-based trust:** penalties discourage bad behavior
- **Calculus-based trust:** cooperation is in the other party's self-interest
- **Relational trust:** built over repeated interactions

| Trust is slow to build and fast to lose: a single violation can cause irreparable damage.

Internet Trust Is Harder

Online trust lacks many traditional clues:

- Identity may be hidden
- Personal characteristics are unclear
- Roles may be ambiguous
- Accountability may be hard to enforce

Mechanisms that restore trust

- **Access control** — keep intruders out.
- **Identity transparency** — bind a virtual agent to a physical person (biometrics, digital signatures, certificates).
- **Surveillance** — real-time **intrusion detection**, or offline **logging and auditing**.
- **Credentials** issued by a trusted authority; **policies** state the conditions for trust; **reputation** accumulates from interaction history and recommendations.

OS and VM Security

Operating System Security Limits

- They support only **two levels**: fully privileged vs fully unprivileged. Windows NT even lets a program inherit **all** privileges of its invoker regardless of trust.
- **Trusted paths** — protected user ↔ software interactions — are largely absent; without them malware can impersonate trusted software.
- An OS is millions of lines and **isolates applications poorly**: platform security collapses to that of the **most vulnerable application**.

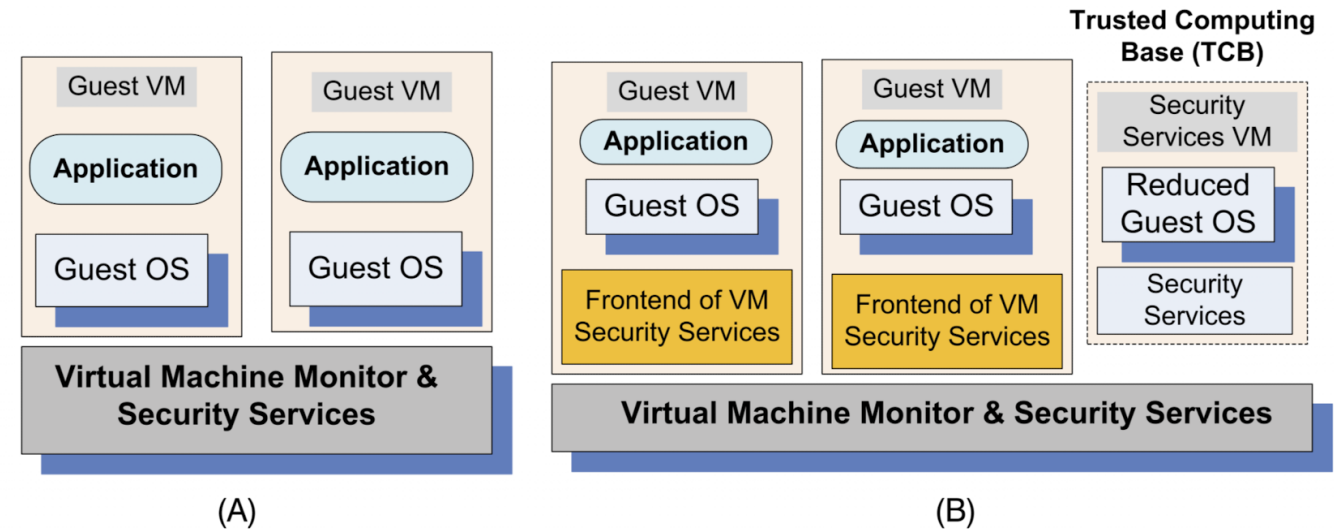
Mandatory vs. Discretionary Security

Security style	Meaning
Mandatory security	Policy logic and security attributes are controlled by a system security administrator
Discretionary security	Individual users or applications may control access decisions

- **Mandatory** security of an OS:
 - Any security policy where the definition of the policy logic and the assignment of security attributes is **tightly controlled by a system security policy administrator**.
 - **Access control policies, authentication usage, cryptographic usage** policies.
 - Security subsystems must be **tamper-proof and non-bypassable**; an OS should confine an application to a **unique security domain**.
 - **Trusted applications** hold special privileges and should run with the **lowest level of privilege** required (fewest permissions needed).
- **Discretionary** mechanisms shift the burden onto users

VM Security Services

- VM Security Services
- VM technology isolates VMs **more strictly** than an OS isolates processes: the hypervisor enforces memory, disk, and network isolation.
- Hypervisors are **less complex and better structured** than OSs, so they respond better to attacks — but a hypervisor sees only **raw state**, while security services work at the level of files and disk blocks



- **(A)** Virtual security services provided by the hypervisor/VMM.
- **(B)** A dedicated **security VM**; a secure **TCB** is necessary.

Hypervisor-Based Threats

NIST-style hypervisor threats include:

1. **Starvation of resources and DoS** for some VMs. Causes: (a) badly configured resource limits; (b) a rogue VM able to **bypass** the limits set in the hypervisor.
2. **VM side-channel attacks** by a VM under the same hypervisor. Causes: (a) lack of proper **inter-VM traffic isolation** due to virtual-network misconfiguration; (b) packet-inspection devices unable to handle high-speed traffic; (c) VM instances built from **insecure images**, e.g., a guest OS without the latest patches.
3. **Buffer overflow attacks.**

The hypervisor improves isolation, but it also becomes a high-value security boundary.

VM-Based Threats

VM-specific risks include:

1. **Deployment of rogue or insecure VMs.** Unauthorized users create insecure instances or perform unauthorized administrative actions. Cause: improper configuration of access controls on VM administrative tasks (creation, launch, suspension, re-activation).
2. **Insecure and tampered VM images** in the repository. Causes: (a) lack of access control to the image repository; (b) no mechanism to **verify image integrity**, e.g., digital signing.

VM Lifecycle Is Not Linear

Traditional patch management assumes forward progress:

```
Install → Patch → Patch → Patch → Current state
```

Virtualization creates a tree:

```
Snapshot
├── VM version A → patched
├── VM version B → dormant
└── VM version C → infected copy
```

Dormant VMs can wake up later and reintroduce old vulnerabilities.

Rollback Risks

Rolling back a VM can reintroduce old state.

- **One-time passwords** sent in the clear can be replayed.
- A rolled-back VM may **reuse** session key, defeating replay protection; even a TCP **initial sequence number** loses freshness, enabling hijacking attacks.
- **Confidentiality**: data spreads across servers and persists; a recorded VM state lets an attacker reach data the owner **tried to destroy**.

Shared Image Risks

IaaS users often start from existing VM images.

Shared images are convenient because they provide:

- Preinstalled OS
- Common libraries
- Tools and frameworks
- Faster deployment

But shared images may contain:

- Credentials
- Keys (SSH keys, etc.)
- Browser history
- Shell command history
- Deleted files that can be recovered
- Backdoors or malicious modifications

AMI Sharing: What Can Leak?

Examples of sensitive artifacts:

- API keys in files such as `pk-*.pem` or `cert-*.pem`
- SSH keys such as `id_dsa` and `id_rsa`
- Login history in `lastlog` and `lastb`
- Browser history
- Shell histories such as `.bash_history`
- Passwords or credit cards in HTTP GET logs
- Deleted files recovered from free disk blocks

Image Hygiene

Before publishing or sharing an image:

- Remove API keys and SSH keys
- Clear browser and shell history
- Remove temporary files
- Rotate credentials
- Patch the operating system
- Disable unnecessary services
- Sign or verify image integrity
- Wipe deleted file blocks

Mobile-Cloud Security

Mobile Devices and Cloud Security

Mobile devices are part of the cloud ecosystem.

They use cloud services to:

- Store data
- Synchronize files
- Access applications
- Perform computation
- Backup user content

But mobile devices face higher exposure because they are portable, easily lost, and frequently use untrusted networks.

Mobile Security Properties

- **Confidentiality:** data cannot be read by unauthorized parties
- **Integrity:** changes to data can be detected
- **Availability:** users can access resources when needed
- **Non-repudiation:** a sender cannot deny actions they originated

Mobile systems include hardware, firmware, OS, applications, baseband processors, and security-specific hardware.

Mobile Threats

- Devices install third-party applications easily, reach clouds over **untrusted cellular and WiFi** networks, and exchange untrusted content.
- Often only a **short passcode**, and possibly **no strong storage encryption**. Location services enable targeted attacks and correlation of the user's associations.

Mobile Security Mechanisms

Recommended mechanisms include:

1. Device encryption, application-level encryption, **remote wipe**.
2. **TLS** on all communication channels.
3. **Sandbox** user-level applications against each other.
4. Device **integrity checks** for boot validation and verified updates.
5. Auditing and logging.
6. Authenticate the device owner.
7. Automatic, regular integrity and compliance checks.
8. **Automated alerts** for policy violations.

Summary

Cloud security combines several layers:

- User behavior and identity
- Application and API security
- Data privacy and encryption
- OS and VM security
- Hypervisor and management-plane security
- Physical and legal trust boundaries

Key idea: Security cannot be attached only at one layer. In the cloud, every abstraction boundary is also a potential attack boundary.